

Patch Perfect.

HARMONIZING WITH LLMS TO
FIND SECURITY VULNS

Caleb Gross, Director of Capability Development
Josh Shomo, Staff Offensive Security Engineer



Agenda



1

Demo

2

Prior Work: LLMs in OffSec

3

Primer: N-Day Vuln Analysis

4

Our Approach: LLM + N-Day

5

Q&A

Capability Development Group @ Bishop Fox



Offensive security professionals specializing in attack surface research and vulnerability intelligence.
Background in computer network exploitation (CNE) at US Department of Defense.



CALEB GROSS

Director of Capability
Development

RIOT

@noperator



U.S. AIR FORCE



JOSH SHOMO

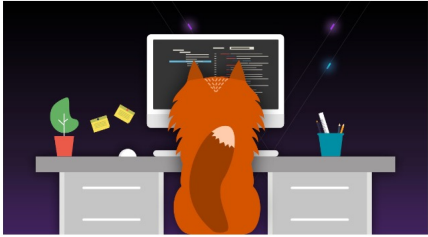
Staff Offensive
Security Engineer

CNODP

@Superbad1337



Vulnerability Research Over the Years



TECH

Jan 13, 2022

**Creating an Exploit:
SolarWinds Vulnerability
CVE-2021-35211**



ADVISORY

May 10, 2022

**CVE-2022-1388: Scan BIG-IP
for Exact Release Versions**



TECH

Aug 02, 2023

**Breaking Fortinet Firmware
Encryption**



TECH

Jan 15, 2024

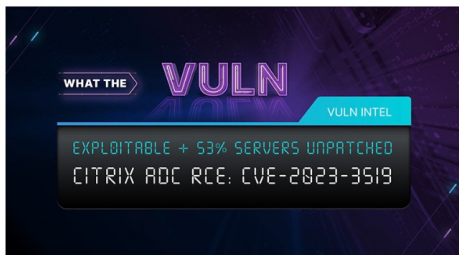
**It's 2024 and Over 178,000
SonicWall Firewalls are
Publicly Exploitable**



TECH

Dec 12, 2019

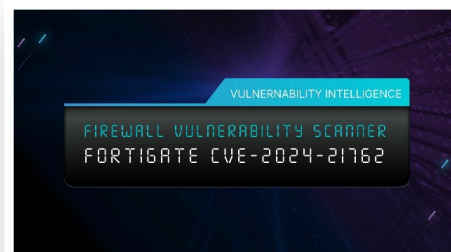
**CVE-2019-18935: Remote
Code Execution via Insecure
Deserialization in Telerik UI**



TECH

Jul 21, 2023

**Citrix ADC Gateway RCE:
CVE-2023-3519 is
Exploitable, and 53% of
Servers Are Unpatched**



TECH

Mar 01, 2024

**CVE-2024-21762
Vulnerability Scanner for
FortiGate Firewalls**



TECH

Aug 04, 2023

**Analysis and Exploitation of
CVE-2023-3519**



TECH

Jun 30, 2023

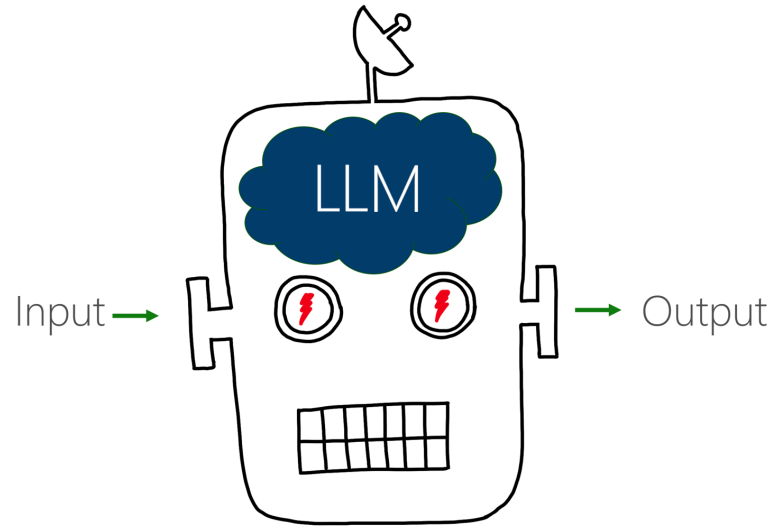
**CVE-2023-27997 Is
Exploitable, and 69% of
FortiGate Firewalls Are
Vulnerable**



TECH

May 17, 2023

**A More Complete Exploit for
Fortinet CVE-2022-42475**



REVOLUTIONARY LEAP FORWARD?

...OR SPICY AUTO-COMPLETE?



A Drama in Three Acts

It's easy to get fooled by incorrect or hallucinated results.

Jason D. Clinton @JasonDClinton · Mar 8

Fully automated vulnerability research is changing the cybersecurity landscape

Claude 3 Opus is capable of reading source code and identifying complex security vulnerabilities used by APTs. But scaling is still a challenge.

Demo: claude.ai/share/ddc7ff37...

This is beginner-level
[Show more](#)

```

}

The vulnerability lies in the fact that the allocation of memory for the private data of the
control element ( kctl->private_data ) is performed without holding the card-
>controls_rwlock lock. This allows multiple threads to allocate memory concurrently,
potentially leading to a heap spraying attack.

An attacker could exploit this vulnerability by repeatedly triggering the
  
```

Sean Heelan @seanhn

@JasonDClinton Is the analysis by Claude correct though? AFAICT CVE-2023-0266 results from missing lock acquisition in the write function, not the add function. The add function is only relevant in that it allows you to free the snd_kcontrol struct that write is working on.

Christopher @Kharosx0

If you're going to tout the capabilities of the LLM for vulnerability research, please ensure the output is correct.

The LLM did not discover the bug as this post claims. It's not even the right function.

It's too easy to get fooled by incorrect or hallucinated results

Jason D. Clinton @JasonDClinton · Mar 8

Fully automated vulnerability research is changing the cybersecurity landscape

Claude 3 Opus is capable of reading source code and identifying complex security vulnerabilities used by APTs. But scaling is still a challenge.

...
[Show more](#)

```

}

The vulnerability lies in the fact that the allocation of memory for the private data of the
control element ( kctl->private_data ) is performed without holding the card-
>controls_rwlock lock. This allows multiple threads to allocate memory concurrently,
potentially leading to a heap spraying attack.

An attacker could exploit this vulnerability by repeatedly triggering the
  
```

chompie @chompie1337

auto complete machine spat out nice sounding words that have no actual relevance to the code it's supposed to be analyzing. pikachu shock face

Christopher @Kharosx0 · Mar 10

If you're going to tout the capabilities of the LLM for vulnerability research, please ensure the output is correct.

The LLM did not discover the bug as this post claims. It's not even the right function....
[Show more](#)

Bill Demirkapi @BillDemirkapi · Mar 11

yea the recent stuff is complete FUD. no, the future isn't gonna be as simple as giving a source file to an LLM and expecting it to find all the bugs.



QUICK DEMO

Use GPT-4 to identify code diff that fixes info disclosure.



Using GPT-4 to Identify an Info Disclosure Vuln

```
(venv) ~/g/b/patch-perfect main:M2??31 3s  
? □
```

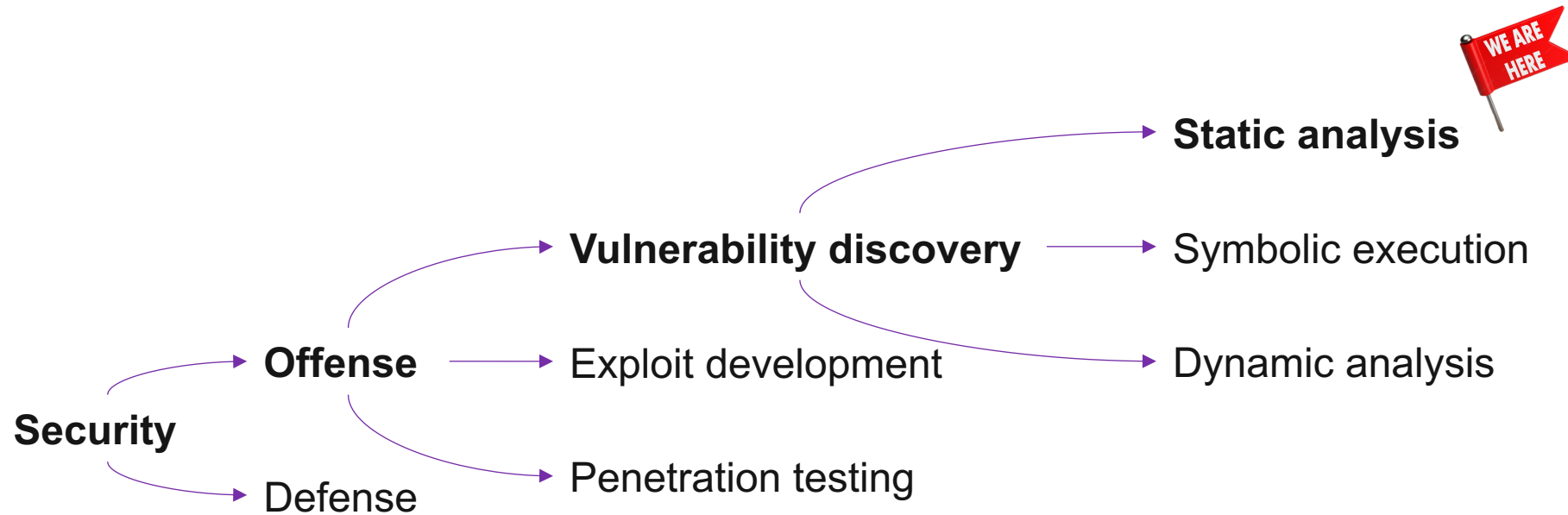

2

PRIOR WORK

LLMS FOR OFFSEC

Hackbots gonna hack.

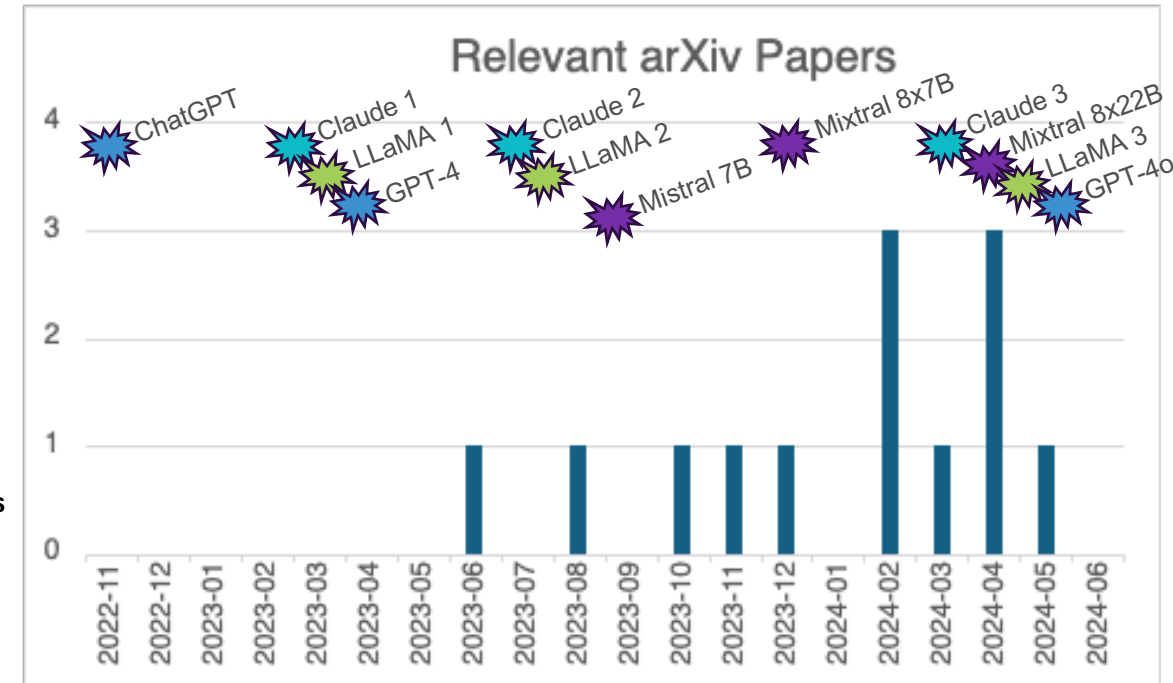
Overview: Application of LLMs to Security



Literature: Application of LLMs to Vulnerability Discovery



Date	ID	Title
2023-06-28	[2306.17193]	Limits of Machine Learning for Automatic Vulnerability Detection
2023-08-20	[2308.10345]	Can [LLMs] Find And Fix Vulnerable Software?
2023-10-04	[2310.02530]	Identifying Vulnerability Patches [...] with Comprehensive Change Contexts
2023-11-21	[2311.12420]	How Far Have We Gone in Vulnerability Detection Using [LLMs]
2023-12-02	[2312.01241]	Just-in-Time Security Patch Detection -- LLM At the Rescue for Data Augmentation
2024-02-19	[2402.11814]	An Empirical Evaluation of LLMs for Solving Offensive Security Challenges
2024-02-27	[2402.17230]	Chain-of-Thought Prompting of [LLMs] for Discovering [...] Software Vulnerabilities
2024-03-25	[2403.17218]	A Comprehensive Study of [...] [LLMs] for Vulnerability Detection
2024-04-03	[2404.02525]	[LLM] for Vulnerability Detection and Repair [...]
2024-04-11	[2404.08144]	LLM Agents can Autonomously Exploit One-day Vulnerabilities
2024-04-15	[2404.09836]	How Far Have We Gone in Stripped Binary Code Understanding Using [LLMs]
2024-05-27	[2405.17238]	LLM-Assisted Static Analysis for Detecting Security Vulnerabilities



Major model releases

-  OpenAI
-  Claude
-  LLaMA
-  Mistral

Literature: Key Insights



- GPT-4 rules them all 🏆
 - "GPT-4 is the only model that can successfully hack **even a single** one-day vulnerability."
 - "GPT-4 outperformed others, with general-domain LLMs performing better than code-domain LLMs due to their ability to generate **longer, more coherent** descriptions."
- Context is everything 📖
 - **Identification**: GPT-4 **exploited 87%** of vulnerabilities when provided with the CVE description.
 - **Discovery**: GPT-4's performance **dropped to 7%** without CVE descriptions, indicating the difficulty in finding new vulnerabilities autonomously.
 - Too much information can be overwhelming—filter out data that's obviously irrelevant.
- Human-in-the-Loop (HITL) 💪 vs. Fully Automated 🤖
 - "The HITL evaluation showed higher success rates [than fully automated] because human feedback significantly **reduced the common failure cases**."
- Small context window 📄
 - "It's usually not possible (or cost-effective) to reason on the entire system at once [...] that means **splitting the work up into smaller chunks**, which is tricky." *
- Non-determinism 🎲
 - "To prevent randomness in the automated workflow portion, we **ran each challenge ten times**."

Model	Pass @ 5	Overall success rate
GPT-4	86.7%	40.0%
GPT-3.5	0%	0%
OpenHermes-2.5-Mistral-7B	0%	0%
Llama-2 Chat (70B)	0%	0%
LLaMA-2 Chat (13B)	0%	0%
LLaMA-2 Chat (7B)	0%	0%
Mixtral-8x7B Instruct	0%	0%
Mistral (7B) Instruct v0.2	0%	0%
Nous Hermes-2 Yi 34B	0%	0%
OpenChat 3.5	0%	0%

Literature: Our Takeaways



- GPT-4 rules them all 🏆
 - We'll explore capabilities and limits of a **general domain**, top tier “off-the-shelf” model.
- Context is everything 📖
 - We'll focus on vuln **identification** (advisory + patch) vs discovery.
- Human-in-the-Loop (HITL) 💪 vs. Fully Automated 🦾
 - We'll **prioritize** functions for a human to analyze.
- Small context window 📄
 - We'll need to figure out how to handle this.
- Non-determinism 🎲
 - ...and probably this, too.





3

N-DAY VULN ANALYSIS

A PRIMER

Use the patch to reverse-engineer the vulnerability.

X-DAY VULNERABILITIES



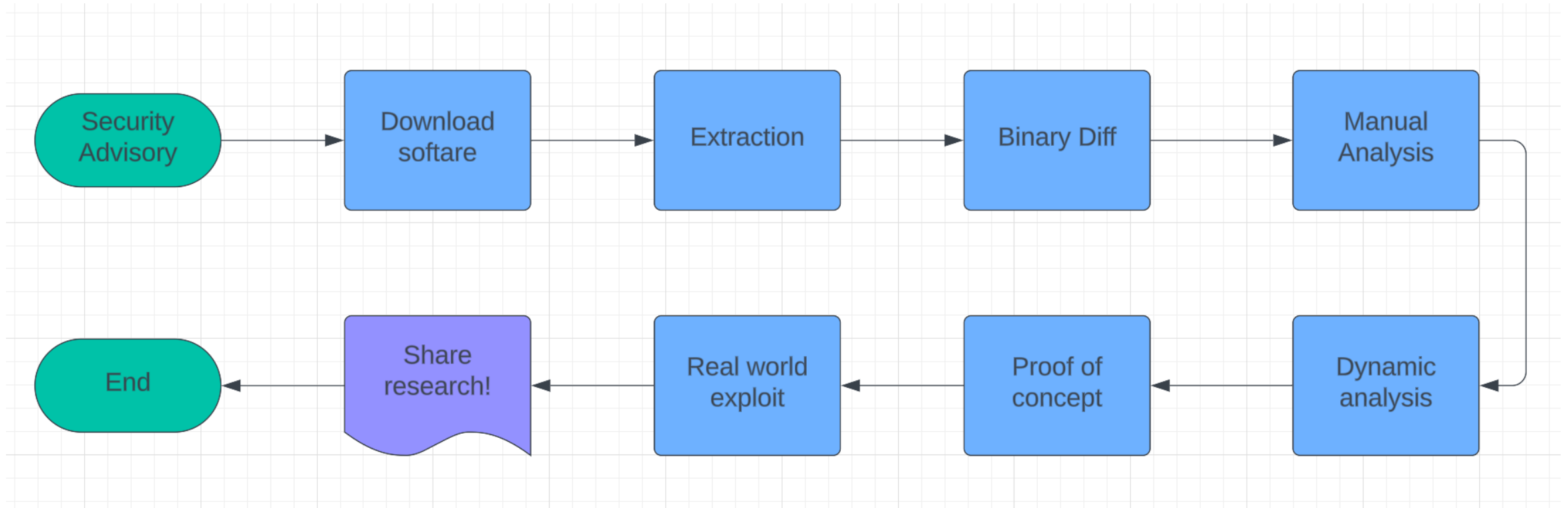
Where N-day vulnerability analysis identification fits into whole overall picture.



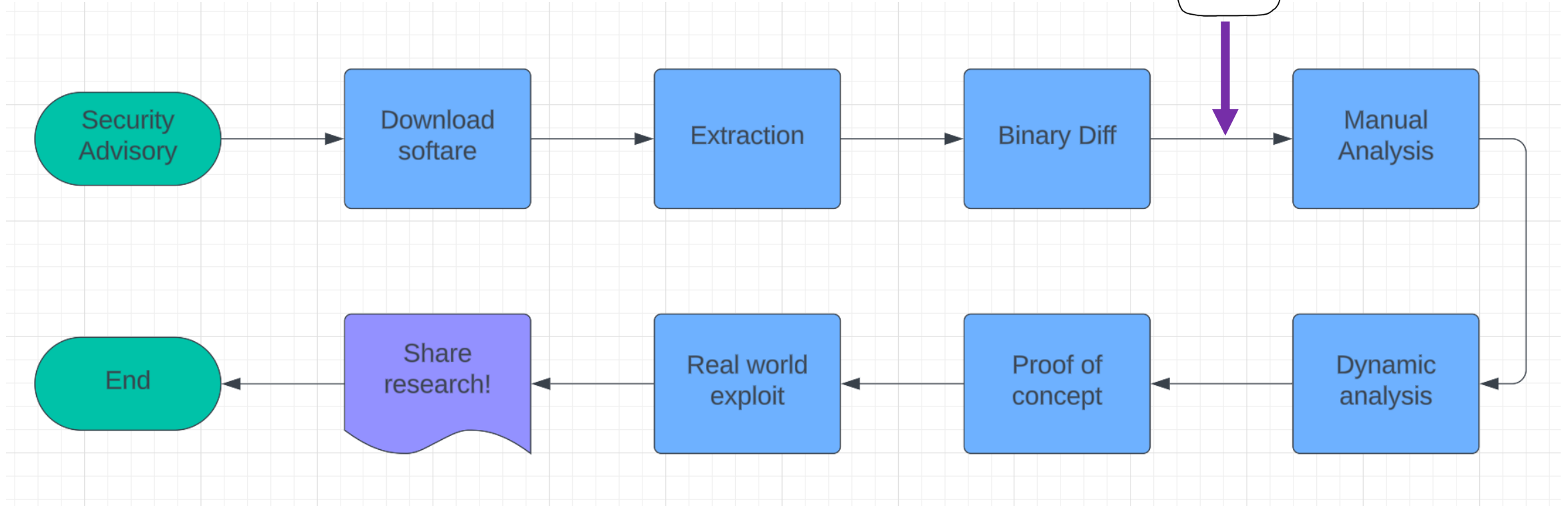
	0-DAY	1-DAY	N-DAY
Definition	Unknown to public and vendor	Publicly disclosed but not yet patched	Known for some period ("N" days) and patch available
Disclosure status	Not disclosed	Recently disclosed	Disclosed
Patch availability	No patch available	No patch available (yet)	Patch available
Defensive measures	Requires immediate investigation and temporary mitigation	Temporary workarounds, heightened monitoring	Regular patch management, system updates
Examples	A new vulnerability in a widely used OS not yet known to the vendor	A newly reported SQL injection flaw in a web app with no patch yet	A buffer overflow patched several months ago, but still exploitable on unpatched systems

This is important.

N-Day Lifecycle



N-Day Lifecycle (+ LLM)

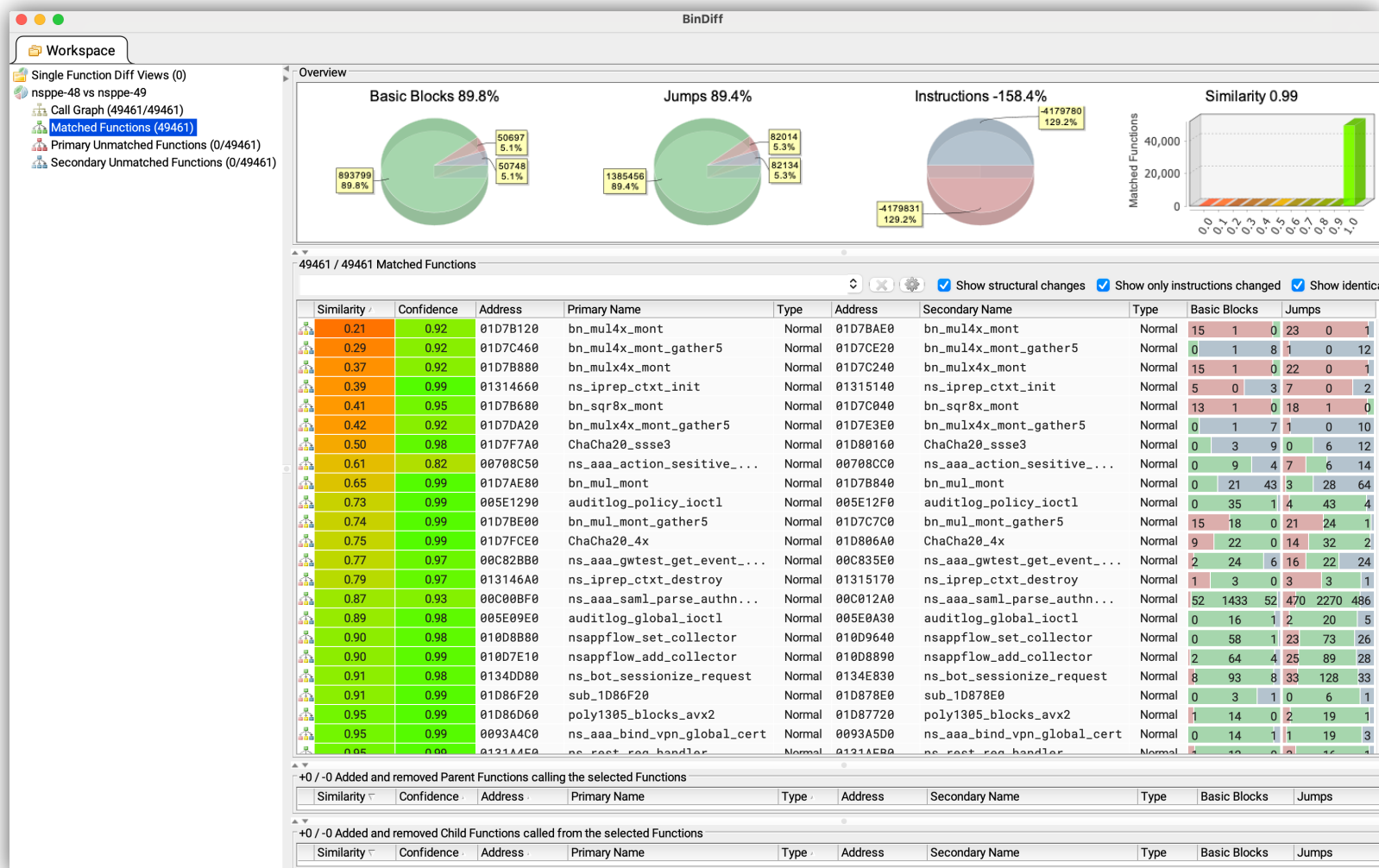


Security Bulletin

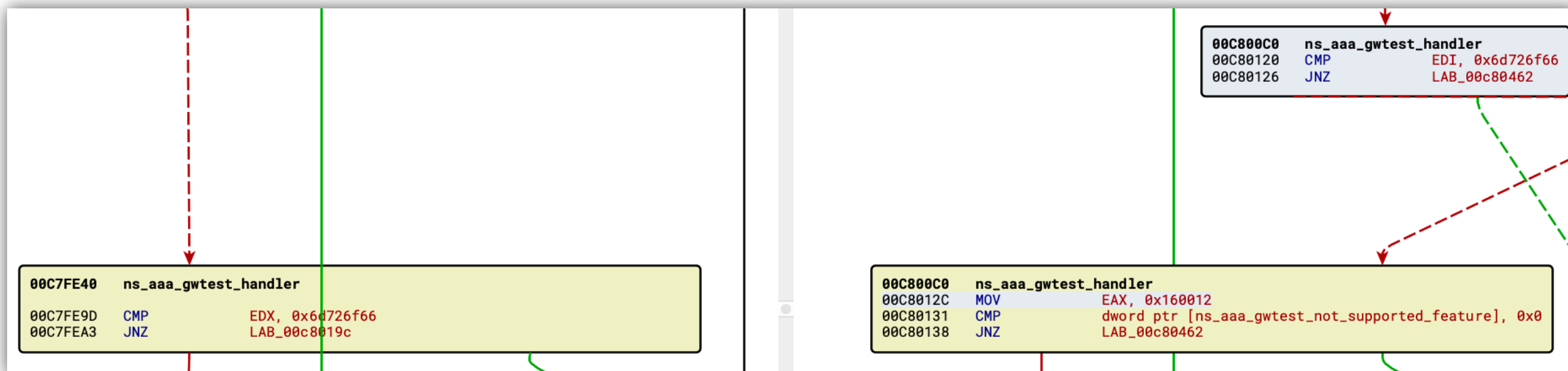


CVE ID	Affected Products	Description	Pre-requisites	CWE	CVSS
CVE-2023-3466	Citrix ADC, Citrix Gateway	Reflected Cross-Site Scripting (XSS)	Requires victim to access an attacker-controlled link in the browser while being on a network with connectivity to the NSIP	i CWE-20	8.3
CVE-2023-3467	Citrix ADC, Citrix Gateway	Privilege Escalation to root administrator (nsroot)	Authenticated access to NSIP or SNIP with management interface access	i CWE-269	8
CVE-2023-3519	Citrix ADC, Citrix Gateway	Unauthenticated remote code execution	Appliance must be configured as a Gateway (VPN virtual server, ICA Proxy, CVPN, RDP Proxy) OR AAA virtual server	i CWE-94	9.8

Patch Diff: High-Level



Patch Diff: Low-Level



Patch Diff: Analysis



- ✦ The next function called is **ns_gwtest_get_valid_fsso_server**
- ✦ 0x80 byte buffer allocated on the stack
- ✦ No stack cookies
- ✦ No ASLR
- ✦ **Dynamic analysis**
- ✦ GET request to /gwtest/formssso?
- ✦ Parameters: event=start&target=foo



TECH

Aug 04, 2023

Analysis and Exploitation of CVE-2023-3519

4

REAL-WORLD DEEP DIVE

Putting LLMs to the test.

CVE-2023-3519



◆ Citrix ADC and Citrix Gateway Security Bulletin

CVE-2023-3519	Citrix ADC, Citrix Gateway	Unauthenticated remote code execution	Appliance must be configured as a Gateway (VPN virtual server, ICA Proxy, CVPN, RDP Proxy) OR AAA virtual server	 CWE-94	9.8
---------------	----------------------------	---------------------------------------	--	--	-----

◆ Patch

- Symbols available
- 22 changed functions (BinDiff)

◆ Vulnerable Function

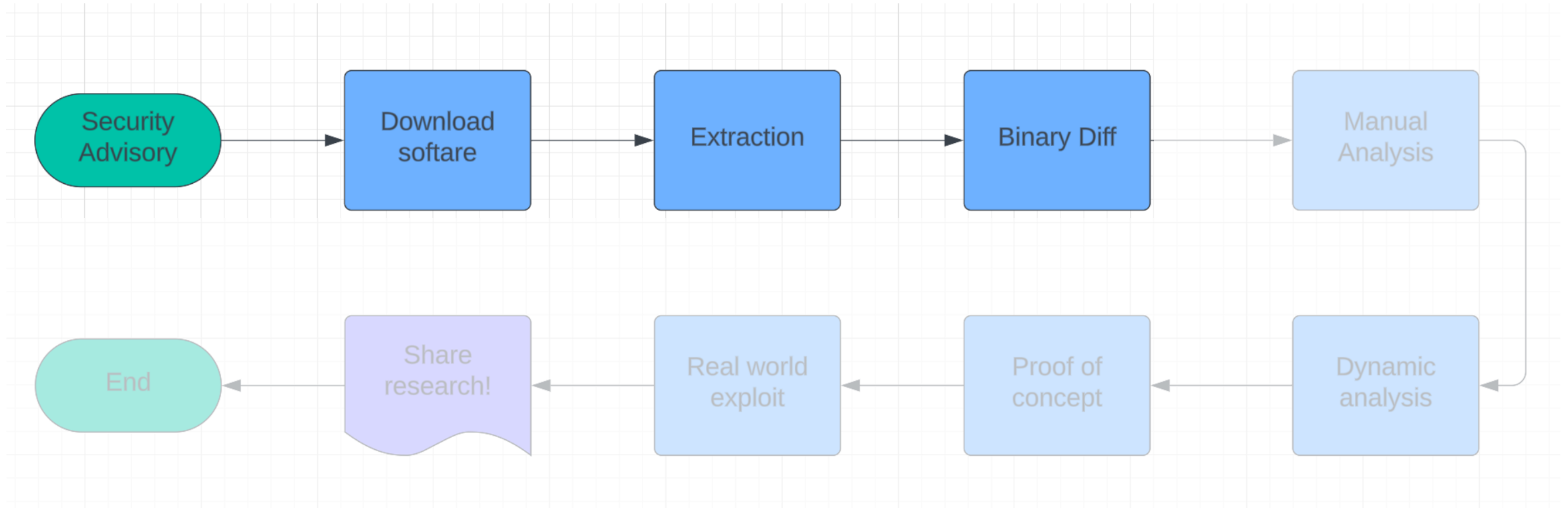
- *ns_aaa_gwtest_handler* – changed code flow around *ns_aaa_gwtest_not_supported_feature*

How do we even...

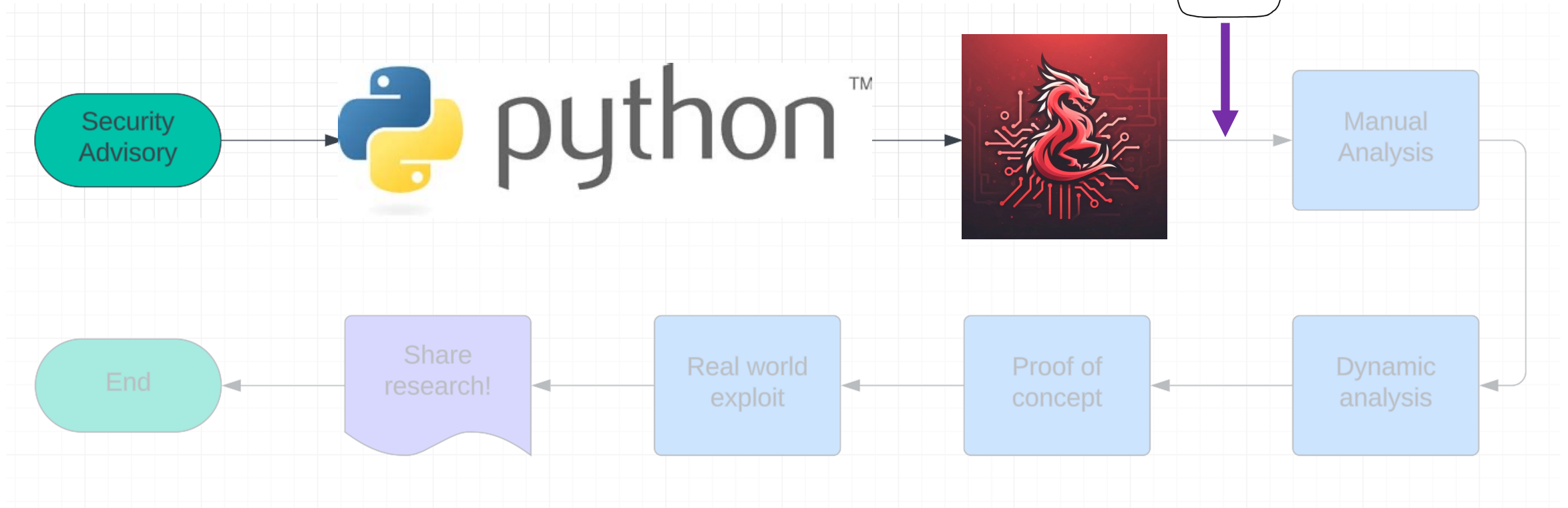


- ✦ Get a text-based pseudocode diff (automatically)?
- ✦ Teach an LLM to read code?
- ✦ Have an LLM look at a security advisory?
- ✦ Judge whether the LLM's output is *meaningful*?

N-Day + Automation



N-Day + Automation



AI Function Context



Does AI score a function differently when given **context** of the diffs of **other functions**?

◆ System Prompt:

You are a cybersecurity expert with 20 years of experience in vulnerability management and reverse engineering. You are researching a new vulnerability, whose security advisory details are in the context below. You look at binary diff analysis of the vendor's patch generated by Ghidra one function at a time and identify if the function is related to the vulnerability.

◆ Context:

- CVE: CVE-2023-3519
- Affected Product: Citrix ADC, Citrix Gateway
- Description: Unauthenticated remote code execution. Appliance must be configured as a Gateway (VPN virtual server, ICA Proxy, CVPN, RDP Proxy) OR AAA virtual server
- CWE: 94 (Improper Control of Generation of Code—"Code Injection")
- CVSS: 9.8

AI Function Context



◆ Multiple functions analyzed in the same “conversation”

◆ User Prompt:

Is the function below related to the vulnerability?

Function Name: ns_iprep_ctxt_destroy

Function Diff: (truncated)

◆ Assistant Answer:

The modification in the `ns\_iprep\_ctxt\_destroy` function hints at...

◆ User Prompt:

Is the function below related to the vulnerability?

Function Name : ns_oauthidp_retrieve_clientid_from_jwt

Function Diff: (truncated)

◆ Assistant Answer:

The provided patch diff shows a change in how base64 decoding is handled in the function...

AI Function Context



◆ One function per “conversation”

◆ User Prompt:

Is the function below related to the vulnerability?

Function Name : ns_oauthidp_retrieve_clientid_from_jwt

Function Diff: (truncated)

◆ Assistant Answer:

The provided patch diff shows a change in how base64 decoding is handled in the function...

AI Function Context



Function Name	Single Function Context	Multiple Function Context
ns_iprep_ctxt_destroy	15	30
ns_oauthdp_compute_cc_access_token	60	75
nsioctlreal_inner	0	0
ns_aaa_action_sensitive_info_cleanup	30	35
ns_aaa_cookie_valid	0	0
ns_oauthdp_retrieve_clientid_from_jwt	85	90
nspm_createdevlink	40	40
ns_sslvpn_send_application_update	45	70

Next step – Analyze all the functions



- ✦ Analyze each function
- ✦ Same system and user prompts
- ✦ Ghidriff - 47 changed functions
- ✦ What does the LLM find?

Everything *could* be a vulnerability



- ◆ High scores across the board
- ◆ Telling me what I want to hear
- ◆ Wild leaps for justification
- ◆ Average vulnerability scores:
 - Mean: 69.74
 - Median: 80.0
 - Mode: 90



Example Wild Analysis



✦ Only function names changed!

```
--- ns_modified_base64_decode
```

```
+++ ns_modified_base64_decode_boundary_check
```

```
-void ns_modified_base64_decode(undefined8 param_1,undefined4 param_2,undefined8 param_3)
```

```
+void ns_modified_base64_decode_boundary_check (undefined8 param_1,undefined4 param_2,undefined8 param_3,undefined4 param_4)
```

```
- ns_base64_decode_common(modified_base64_to_ascii_table,param_1,param_2,param_3);
```

```
+ ns_base64_decode_boundary_check_common  
(modified_base64_to_ascii_table,param_1,param_2,param_3,param_4);
```

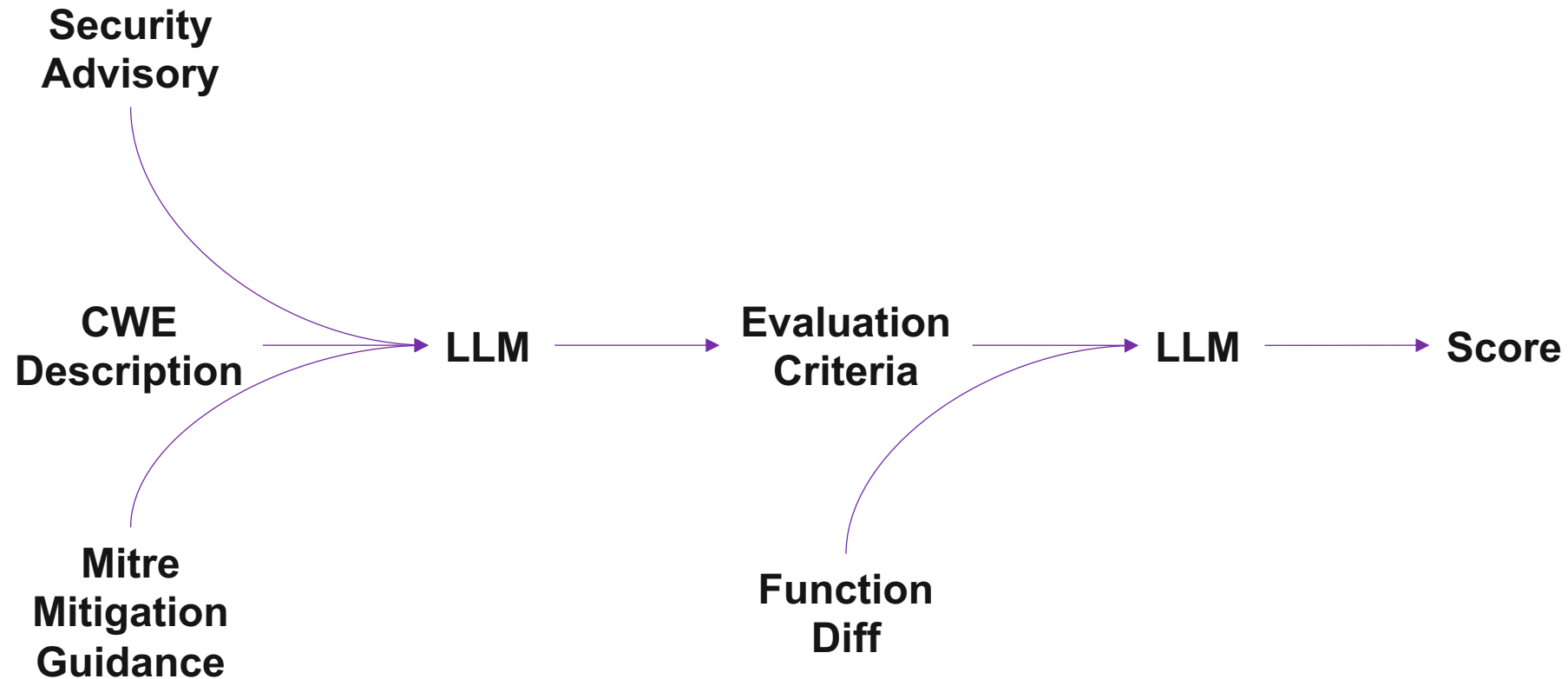
LLM attempt at reasoning



- ◆ **1. Functionality Review:**
 - “The primary role of both functions seemingly involves decoding base64 data”
- ◆ **2. Vulnerability Context:**
 - “CVE-2023-3519 allows for unauthenticated remote code execution.”
 - “Base64 encoding/decoding is a common vector for such vulnerabilities”
- ◆ **3. Boundary Check Addition:**
 - “The significant change in the patched function is the addition of a boundary check”
- ◆ **4. Impact of Change:**
 - “The addition of boundary checks in the context of base64 decoding directly addresses a common exploit vector”
- ◆ **5. CVSS Score:**
 - “The CVSS score of 9.8 indicates a critical severity”

- ◆ **“I would rate it a 95 out of 100”**

Can LLMs write better prompts?



Can LLMs write better prompts?



◆ User prompt:

Given your context of CVE-2023-3519, develop a list of evaluation criteria to rank each function. Make sure your criteria highlights the intersection of the vulnerability's description, the vulnerability class shown by the CWE, and code changes that would be necessary to address this vulnerability.

◆ Assistant response (summarized):

- Sanitization of Inputs
- Authentication and Authorization Checks
- Error Handling and Logging
- Code Execution Flow Controls
- Configuration and Default Settings Adjustments
- Patch Impact and Compatibility
- Documentation and Guidance for Administrators

Can LLMs write better prompts?



```
"role": "assistant",
"content": "To conduct a thorough evaluation and ranking of each function that was changed in the security patch for CVE-2023-3519, I would develop a set of
criteria focusing on several key areas. These areas are designed to closely intersect with the vulnerability's nature (unauthenticated remote code execution),
its class as defined by CWE-94 (Improper Control of Generation of Code - 'Code Injection'), and the essential code alterations to mitigate such a
vulnerability. The criteria are as follows:\n\n1. **Validation and Sanitization of Inputs:**\n    - **Scope of Validation Added/Enhanced:** Evaluates how well
the function now scrutinizes incoming data, especially from untrusted sources. Given the code injection nature of the vulnerability, checks for unusual or
malicious patterns that could lead to arbitrary code execution are critical.\n    - **Sanitization Mechanisms Implemented:** Assess the measures put in place
to cleanse data inputs, ensuring that harmful data does not reach execution paths.\n\n2. **Authentication and Authorization Checks:**\n    - **Strengthening of
Authentication Checks:** Since the vulnerability allows unauthenticated access, we look at how authentication mechanisms have been fortified to prevent
unauthorized access.\n    - **Authorization Mechanisms Verification:** Evaluate how the function verifies the legitimacy of an authenticated entity to perform
the requested operation, thereby providing a layer of security against unauthorized actions.\n\n3. **Error Handling and Logging:**\n    - **Improvement in
Error Messaging:** Review how the function's error handling mechanisms have been updated to prevent leakage of sensitive information, which could be exploited
for further attacks.\n    - **Enhanced Logging for Suspicious Activities:** The addition or improvement of logging capabilities to track and alert on
potential exploitation attempts can be an important mitigation and investigation tool.\n\n4. **Code Execution Flow Controls:**\n    - **Implementation of Safe
Execution Contexts:** Assess the mechanisms put in place to ensure that execution of dynamic code, if unavoidable, occurs in a manner that minimally exposes
the system to risk.\n    - **Restrictions on Code Generation and Execution:** Examine how the function limits or entirely eliminates situations where code
could be injected and executed, aligning directly with the CWE-94 classification.\n\n5. **Configuration and Default Settings Adjustments:**\n    - **Hardening
of Default Configuration:** Evaluate changes that make the system's default state more secure against attacks, requiring explicit action from administrators
to enable potentially vulnerable functionalities.\n    - **Options for Enhanced Security Measures:** The introduction of new settings that allow administrators
to increase security based on their risk profile and operational requirements.\n\n6. **Patch Impact and Compatibility:**\n    - **Compatibility with Existing
Environments:** How well the function accommodates existing setups without introducing significant disruption.\n    - **Performance Implications:** Any changes
that could significantly impact system performance should be scrutinized, as they might lead to avoidance of the patch implementation.\n\n7. **Documentation
and Guidance for Administrators:**\n    - **Clarity and Comprehensiveness of Documentation:** The quality of documentation accompanying the patch, detailing
the vulnerability, affected configurations, and steps for mitigation.\n    - **Guidance on Future Prevention:** Any advice or best practices shared for
administrators to prevent similar vulnerabilities from occurring or being exploited.\n\nThis evaluation approach allows an in-depth review and prioritization
of the functions changed by the security patch, highlighting how each contributes to mitigating the risk associated with CVE-2023-3519. It bridges the gap
between theoretical vulnerability analysis and practical, actionable security improvements."
```

Can LLMs write better prompts?



- ✦ So how'd it do???
- ✦ Assistant response:

Can LLMs write better prompts?



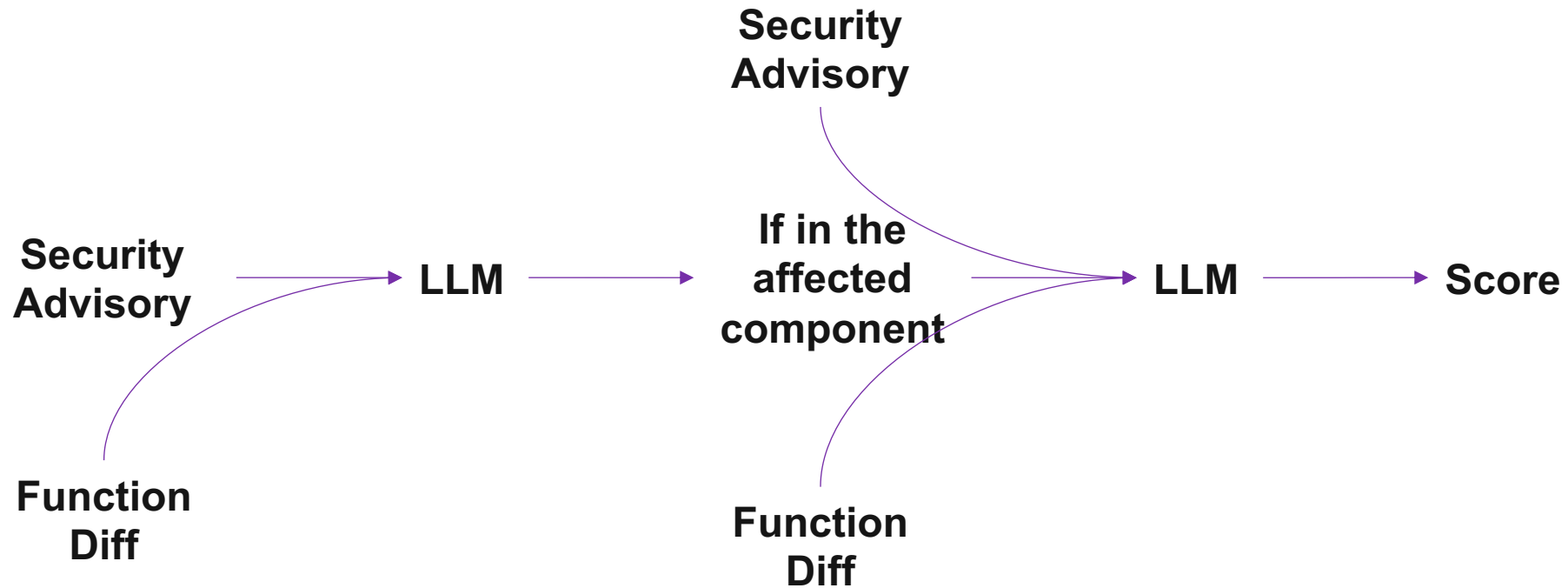
- ◆ Given the detailed analysis of each function, we can rank the top 10 functions most likely related to addressing the security vulnerability described by CVE-2023-3519, based on the provided insights and the direct implications of the changes made in the context of preventing unauthenticated remote code execution vulnerabilities:

- ◆ **1. ns_modified_base64_decode_boundary_check**
 - Introduced additional input boundary checks directly targeting vulnerabilities like CVE-2023-3519.

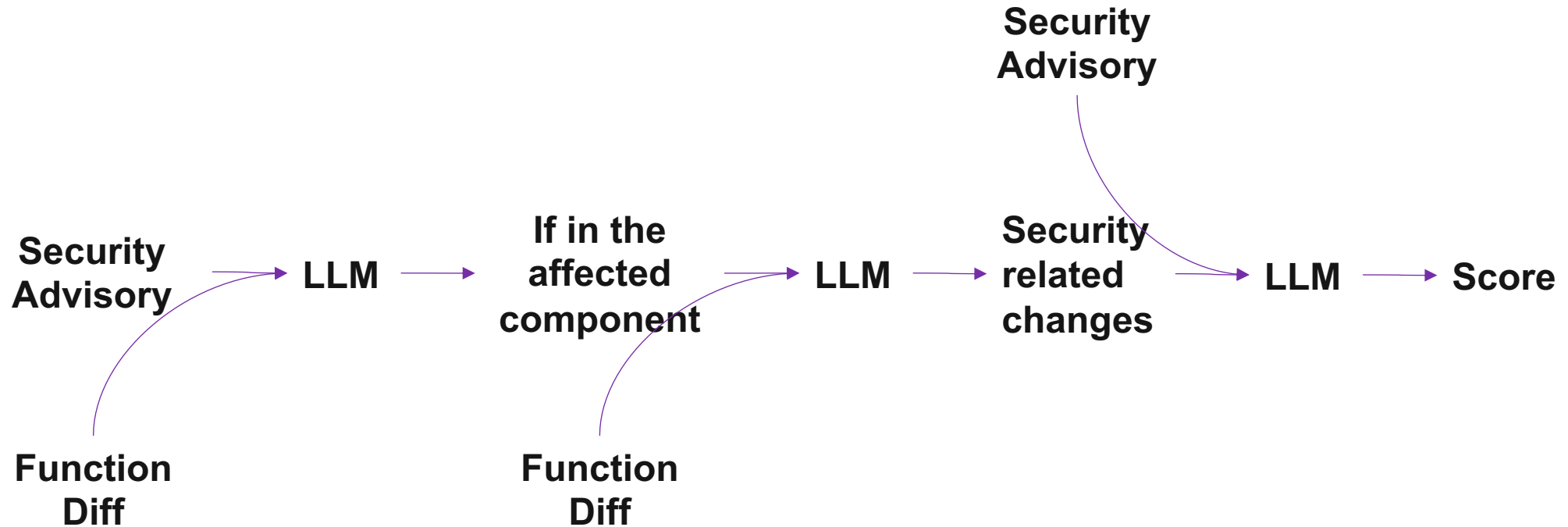
- ◆ **2. ns_oauthdp_compute_cc_access_token**
 - Input length check and memory copy modifications to mitigate risks of buffer overflow and code injection.

- ◆ **3. ns_oauthdp_retrieve_clientid_from_jwt**
 - Enhanced boundary checks in handling JWT, critical for preventing code injection in authentication flows.

Split up the prompt



Split up the prompt

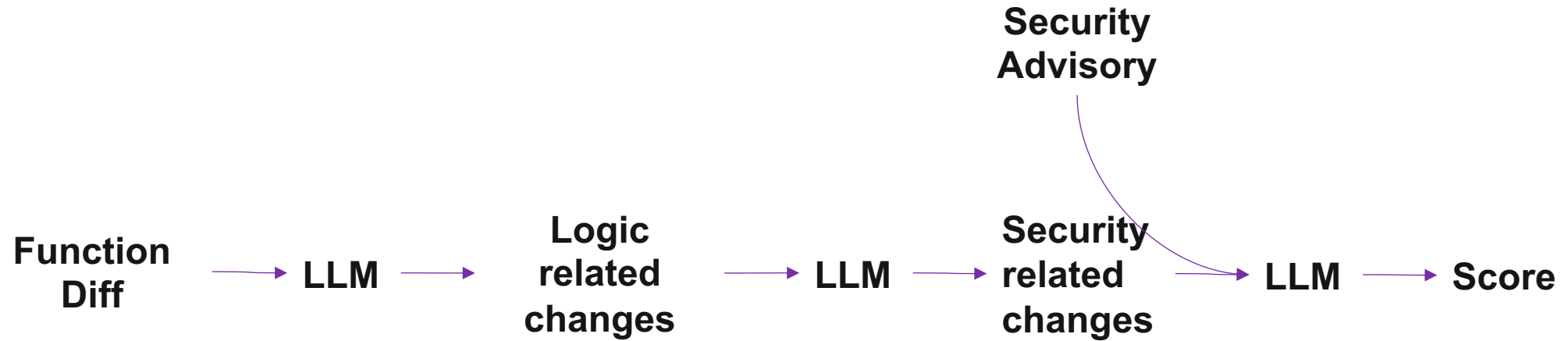


Split up the prompt

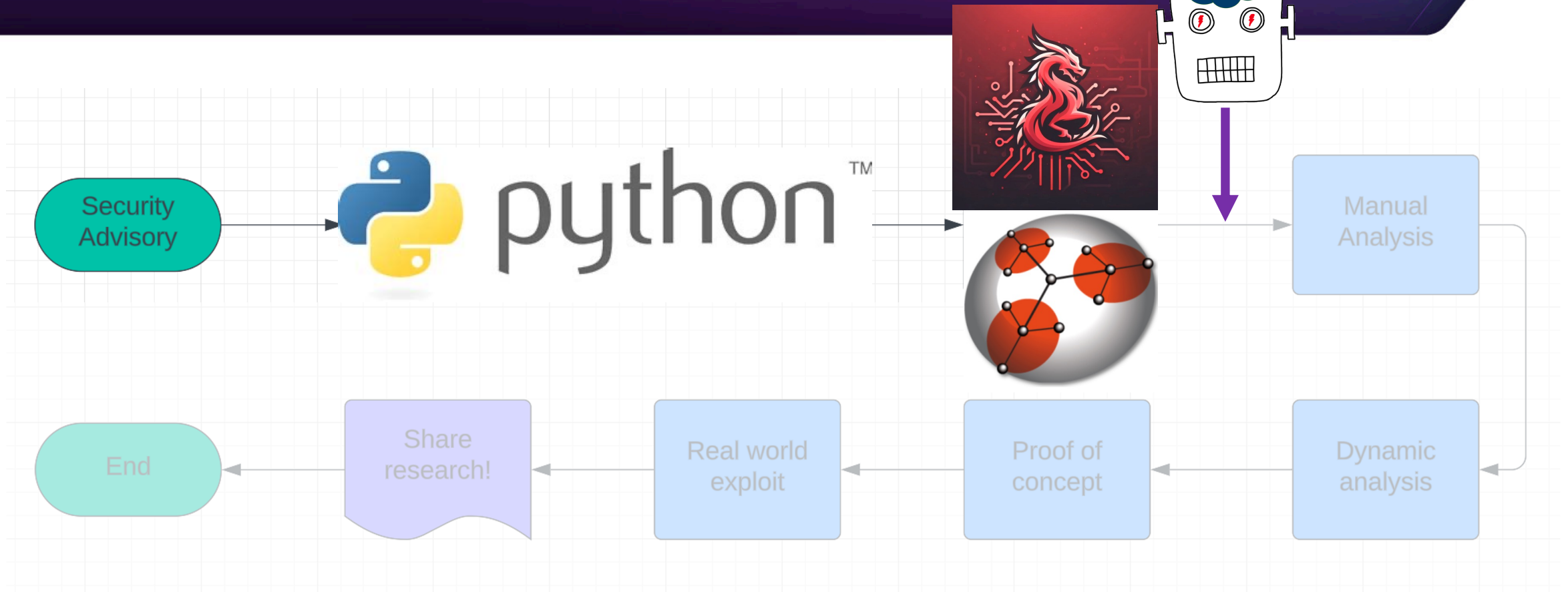


- ◆ **Good:**
- ◆ Filtering out unrelated functions
- ◆ In one test ns_aaa_gwtest_handler ranked #4
- ◆ Could be better

Summarize logic changes



N-Day + Automation



Adding BinDiff



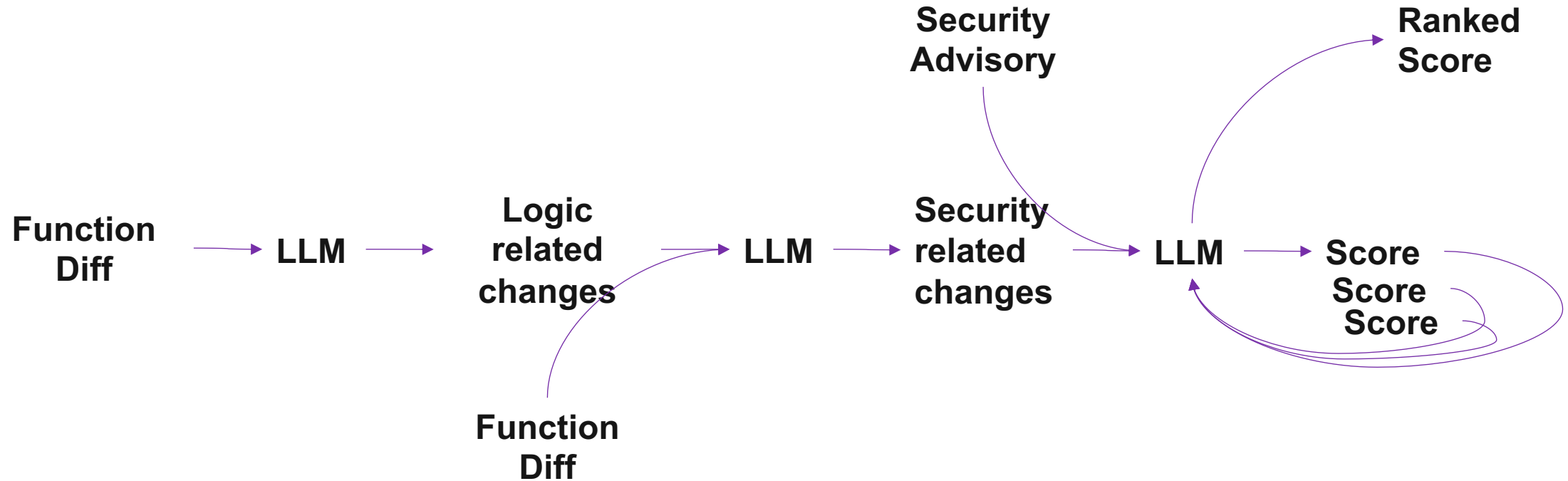
◆ Ghidriff:

- Decompiled unified diff
- Additional details like added strings and function call/calling
- Gets tripped up on symbol names (i.e., lack of symbols)

◆ BinDiff

- Fewer results, higher signal
- Compares at assembly level
- No exportable diff

Context Aware Scoring



Victory



- ◆ Assistant Ranking:
- ◆ Given the full context of all the functions and a re-evaluation of the necessary security changes to address the vulnerability described in the security advisory (CVE-2023-3519), which involves an unauthenticated remote code execution vulnerability in Citrix ADC and Citrix Gateway, particularly affecting configurations as a Gateway or AAA virtual server, the focus should be on functions that are directly related to handling unauthenticated requests, input validation, and those that could potentially be involved in code execution paths due to improper input handling or code injection vulnerabilities.

Victory



- ◆ Assistant Ranking:
- ◆ Given the full context of all the functions and a re-evaluation of the necessary security changes to address the vulnerability described in the security advisory (CVE-2023-3519), which involves an unauthenticated remote code execution vulnerability in Citrix ADC and Citrix Gateway, particularly affecting configurations as a Gateway or AAA virtual server, the focus should be on functions that are directly related to handling unauthenticated requests, input validation, and those that could potentially be involved in code execution paths due to improper input handling or code injection vulnerabilities.
- ◆ 1. **ns_aaa_gwtest_handler**
 - Initially scored 85. This function is directly called by ns_vpn_process_unauthenticated_request, making it a prime candidate for being involved in handling unauthenticated requests, which is a key aspect of the described vulnerability.
 - Revised Score: 95. Its direct involvement with unauthenticated requests and potential for input validation improvements makes it highly relevant.



CVE-2024-21762



◆ Fortinet FortiOS Security Bulletin

- A out-of-bounds write vulnerability [CWE-787] in FortiOS and FortiProxy may allow a remote unauthenticated attacker to execute arbitrary code or command via specially crafted HTTP requests.

◆ Patch

- No symbols available
- 8 changed functions (BinDiff)

◆ Vulnerable Function

- sub_018F48D0
 - New check if a register is greater than 0x10
 - error message: "%s: %d invalid chunk length string"

**PSIRT**

Out-of-bound Write in sslvpnd

Update prompts for new vuln



- ✦ Function diff analysis
 - Handle lack of symbols
- ✦ Security related analysis
 - Remove function references which would just be addresses
- ✦ Advisory ranking analysis
 - Add new advisory info

First Rankings



- | | | | |
|----|-------------|-------------------|----------------------------------|
| 1. | sub_198BCE0 | Revised Score: 98 | |
| 2. | sub_18F48D0 | Revised Score: 95 | ← The actual vulnerable function |
| 3. | sub_B4E380 | Revised Score: 90 | |
| 4. | sub_B55040 | Revised Score: 85 | |

The introduction of boundary checks and enhanced error handling in this function is directly relevant to mitigating out-of-bounds write vulnerabilities. The focus on handling chunk lengths and boundary conditions is particularly pertinent to processing HTTP requests securely, making it highly likely to be associated with the vulnerability fix.



First Rankings

- ✦ Why Second?
- ✦ Let's look at 1st place sub_198BCE0

CVE-2024-23113



◆ Fortinet FortiOS Security Bulletin

- A use of externally-controlled format string vulnerability [CWE-134] in FortiOS fgfmd daemon may allow a remote unauthenticated attacker to execute arbitrary code or commands via specially crafted requests.

◆ Patch

- No symbols available
- 8 changed functions (BinDiff)

◆ Vulnerable Function

- sub_B4E380 – added “%s” to snprintf call



Update prompts for new vuln



- ✦ Function diff analysis
 - Handle lack of symbols
- ✦ Security related analysis
 - Remove function references which would just be addresses
- ✦ Advisory ranking analysis
 - Add new advisory info

First Rankings



- | | | | |
|----|-------------|--------------------|----------------------------------|
| 1. | sub_B4E380 | Revised Score: 100 | ← The actual vulnerable function |
| 2. | sub_B55040 | Revised Score: 100 | |
| 3. | sub_198BCE0 | Revised Score: 80 | |
| 4. | sub_B732D0 | Revised Score: 40 | |

These changes appear related to security. The modification in the handling of string formatting, **specifically the shift from using a dynamically obtained format string to a hardcoded `\"%s\"` in `snprintf`**, directly addresses concerns related to CWE-134, Use of Externally-Controlled Format String. This vulnerability occurs when a format string can be influenced by an attacker, potentially allowing arbitrary code execution or causing a crash. By hardcoding the format string, the update mitigates the risk of format string vulnerabilities, making it a security improvement.

Let's recap so far...



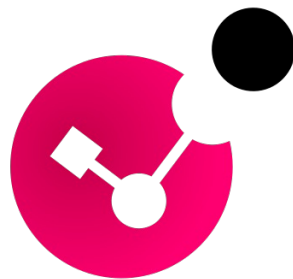
Given an advisory and patch diff, we can:

- ✓ Describe each changed function
- ✓ Determine if it's a security-related change
- ✓ Estimate how likely the change fixed a given vulnerability
- ✓ List the most likely candidates

...and apply this to a more recent example

Given an advisory and patch diff, we can:

- ✓ Describe each changed function
- ✓ Determine if it's a security-related change
- ✓ Estimate how likely the change fixed a given vulnerability
- ✓ List the most likely candidates



CHECK POINT™

The screenshot shows a web browser window with the URL `support.checkpoint.com/results/sk/sk182336`. The page is titled "Preventative Hotfix for CVE-2024-24919 - Quantum Gateway Information Disclosure". A red banner at the top says "Please read this important update from Check Point." with a "Security Alert: High" indicator. The page lists the affected products: CloudGuard Network, Quantum Maestro, Quantum Scalable Chassis, Quantum Security Gateways, and Quantum Spark Appliances. It also lists the affected versions: R77.20 (EOL), R77.30 (EOL), R80.10 (EOL), R80.20 (EOL), R80.20.x, R80.20SP (EOL), R80.30 (EOL), R80.30SP (EOL), R80.40 (EOL), R81, R81.10, R81.10.x, and R81.20. The last modified date is 2024-06-04. The "Solution" section describes the vulnerability and the impact of the hotfix.

Product
CloudGuard Network, Quantum Maestro, Quantum Scalable Chassis, Quantum Security Gateways, Quantum Spark Appliances

Version
R77.20 (EOL), R77.30 (EOL), R80.10 (EOL), R80.20 (EOL), R80.20.x, R80.20SP (EOL), R80.30 (EOL), R80.30SP (EOL), R80.40 (EOL), R81, R81.10, R81.10.x, R81.20

Last Modified
2024-06-04

Solution

Following our security update on May 27, 2024, Check Point's dedicated task force continues investigating attempts to gain unauthorized access to VPN products used by our customers. On May 28, 2024 we discovered a vulnerability in Security Gateways with IPsec VPN in Remote Access VPN community and the Mobile Access software blade (CVE-2024-24919). Exploiting this vulnerability can result in accessing sensitive information on the Security Gateway. This, in certain scenarios, can potentially lead the attacker to move laterally and gain domain admin privileges.

Arbitrary File Read

- ◆ Exploited in the wild
- ◆ Faulty use of the `strstr` function, allowing path traversal and arbitrary file read (e.g., `/etc/shadow`).
- ◆ Lots of code changed in the patch
- ◆ 3 functions changed/added to fix this issue:
 - `sub_80F09E0`
 - `sanitize_filename`
 - `send_path_traversal_alert_log`

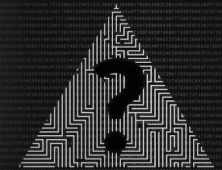
```
4:  mov     [esp+0Ch], eax
4:  lea     eax, (aSuspectedPathT - 841FFF4h)
4:  [esi]; "Suspected path traversal attack from: %"...
4:  mov     [esp+8], eax; format
4:  mov     eax, 100h
4:  mov     [esp+4], eax; maxlen
4:  call    _snprintf
4:  mov     dword ptr [esp], 0
```

 Labs

Check Point Security Gateway

Wrong Check Point

CVE-2024-24919



Check Point Quantum Gateway

CVE-2024-24919



VULNERABILITIES

What's Going on With Check Point (CVE-2024- 24919)?

 censys

BLOGS

May 31, 2024: Arbitrary File Read in Check Point VPN Gateways [CVE- 2024-24919]

Lots of changed functions

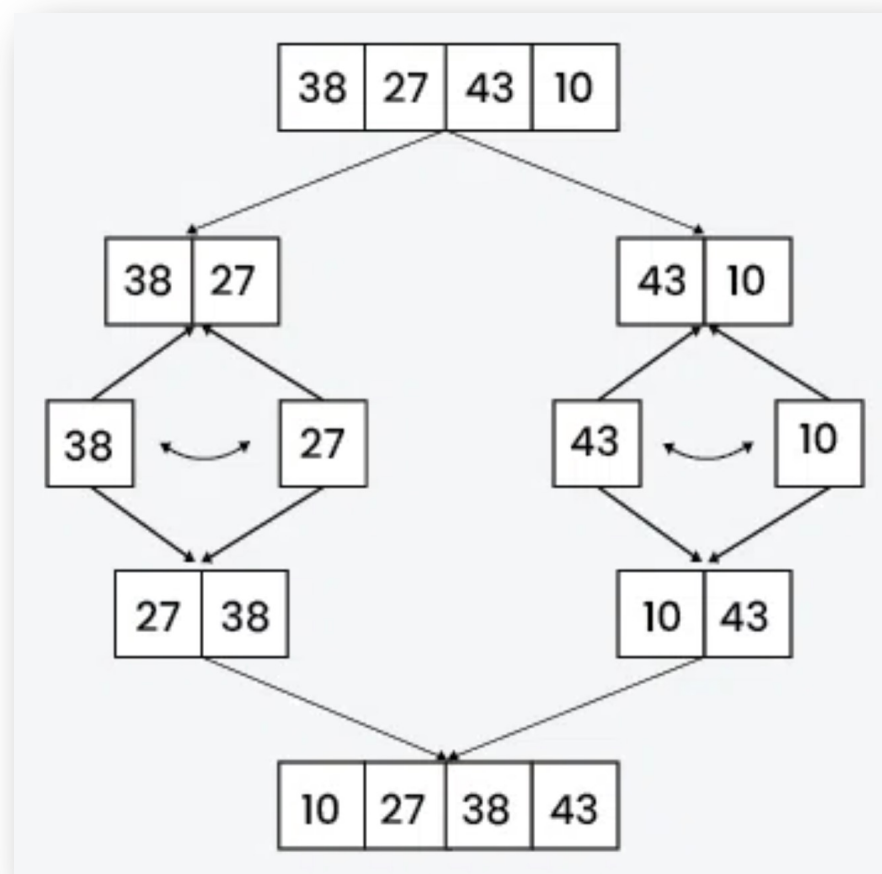


send_message FUN_081cf990 dag_inits BruteForceAttackPrevention set_dpd_init_seq_num FwIkeInitiator update_dag_objects updateConf FUN_08108b00 setGTPRestartCounterToKernel FUN_082fa950 getIKEPeerObj FwIkeEngine unban_client_ip_address obtain_IP_address_for_user obtain_IP_address_for_user_DHCP createAUforCertUsers_ccc_CB mark_initial_contact_pending clear FwIkeResponder FUN_080d3880 free_challenge_buf FUN_0820c6e0 FUN_081a20a0 setinfo tunnel_list_by_conn ipsechoost_from_ipaddr obtain_IP_address_for_user_IPpool Association tcpt_conn_end_handler FUN_082697d0 FUN_080e49f0 FUN_081aa3f0 FUN_080f09e0 ikev2_SAs_to_kernel update_inbound_SPI_to_instance_map resetFailedAttempts loadL2TPLookup tunnel_list registerAssignedIP rasta_mark_sessions_for_reuse licdb_Lic_destroy_imp au_prepare_groups_with_cache RA_VPN_IDP_Client_reconf dpd_or_passive_listener obtain_IP_address_for_user_LIST getLoginOptionsSet L2TP_CPL0G_log geOrCreatetLogUIdForIkeCCC getFailedAuthAttemptThreshold FUN_081a02d0	AddNegotiation getUseCRLForRevocationMethodFromRegistry PPP_destroy_state getSelectedRealm FUN_0830fcc0 getResolvedMyAndPeerIp iSendDeleteIKESA slim_ip_allocated handle_dpd_notification_ikev1 FUN_0818ba00 http_vpnd_fetch_user_timeout handle_dhcp_server_msg FUN_081b7690 FUN_081e50b0 user_cache_reconf FUN_080bd4c0 MarcipanGateway FwIkeDeleteNegCxt RestartNegsAfterDel getInterestingGroups getCreationTimeOfCCCSession storeChildSAs do_accounting_login_for_user_RADIUS handleFinishSNXCertAsyncCb fwisakmp_delete_sa_by_cookies FUN_081558a0 resetMarcipan saveL2TPSession FUN_081b61b0 FUN_081dfeb0 saveL2TPTunnel notify_login FUN_08159fb0 FUN_081568d0 IsUserAuthenticatedWithMachineCert FUN_08283ef0 licin_nsrusers_imp updateTableEntry link_prob_layer_init Initialize cleanTunnel authenticate overrideIkeNATDByRouteToIPv4Peer update_timeout_on_tunnel_instance_orig_route ~BruteForceAttackPrevention FUN_081b7e90 vpn_set_hide_nat_dag_from_sync set_client_settings_ra_ip_gw_behind_nat ~RastaConnection FollowRoamingClients ike_fetch_user	unregister_probe_link set_ra_ip_gw_behind_nat isDefaultRealmDisabled overrideIkeNATDByRouteToPeer AUAuthIOFunc init_key ~TransmissionRequest SASTore FUN_0830e500 FUN_08164210 WakeNegotiations tcpthash_init FUN_08208570 getFailedAuthDelayInSeconds http_vpnd_crl_validation_handler PPP_down_layer_disconnected MarcipanGateway ResolvePeer FUN_08100530 SC_disconnect_tunnel_wrapper FwIkeAfterAsyncCertHandling set_auth_groups_fetched vpn_ipsec_spi_notify SC_suspend_tunnel process_cpas_tcpt_trap checkValid tcpt_get_if_num UpdateDAGIP http_vpnd_check_user_grps_cb SC_get_sa_from_tunnID release_tnlmon_prev_cb FUN_08166b80 IkeSAFromStateDo FUN_081f8830 set_multicast_group_sa DestroyFeatureList FUN_08247b40 FUN_082e73f0 FwIkePhase1End FUN_08263310 L2TP_enforce_PPP_user_limitations FUN_08148150 isakmp_check_user_limitations FUN_082921b0 del_lic FUN_080f0940 FUN_08159150 saveL2TPLookup DestroyBuf create_login_log RA_VPN_IDP_Client_update	createCCCSession SC_disconnect_tunnel setSeqNumToKernel FUN_081559e0 verify_peer_auth create_dhcp_rec main PreferredMEPGW_SetEntry call_dpd_callback isFeatureEnabled GetPreaturesFromTable getPenaltyTimeInSeconds RequestByDPD FUN_08147860 rekeyed_outbound_to_kernel loadFromNDB InitXAuthB4Send ikev2_esp_sa_expired FUN_0825f290 CreateNewNegotiation isValidIpAddr ikelogging_get_data tnlmon_action_generic receive_fwuserc_isakmp_reply_S send_dpd Association matchAndSortCertsForVal saveL2TPCluster slim_release_tunnel updateFailedAttempts FUN_08315270 slim_get_tunnel_id obtain_IP_address_for_user_RADIUS DeschedDHCPRecOpaque FUN_080f0790 ipalloc_cancel_address metagroup_ra_group_end FUN_081ab660 issueLicense disconnect_all_conns FwIkeP1FetchUser FUN_08208900 saveL2TPCluster FUN_080fab50 FUN_081e05c0 slim_disconnect_mobile_vpn fwisakmp_new_pull_key_sa_notify get_resolver_stat_name tnlmon_transmitter_cb vpn_ikesa_deleted_trap initCustomLoginOptionsSet	getIntModuleGlobalParameter TalkToEngine fwCert_ValPeerCertAndFindKey slim_release_cookie set_dhcp_discover_timeout InitXAuthConnectAuAuth removeTableEntry verifyCert L2TP_PPP_event_ipopen http_vpnd_fetch_user_cb slim_server_fetch_user_timeout FUN_082c8ac0 send_data_to_client get_registry_value getStaticallyResolvedAddrByPeer FUN_08292310 slim_cpas_trap FUN_0812dcb0 getRealmNameFromIkeSA ipalloc_extend_lease_handler check_eap_user FUN_0826be90 getNumFailedAttempts createLogOutForCCC get_conn_type_from_authinf_table narrow_routing_recreate_do rasta_rpc_connect_async_notify initIkev2 store_hide_nat_daip vpn_update_isakmp_user interface_resolve_cb licdb_add_license Association marcipan_bound receive_fwuserc_isakmp_reply ikev2_validate_peer_cert FUN_08207c00 create_logout_log DeschedNegCbs initLoginOptionsSet insert_to_ccc_iphone_sessions vpn_snx_unban_client_ip FwIkeRespMainMode FUN_0817a070 IKE_LS_Resolver_Logic getAllMatchingRealmsFromCCCSet[abi:cxx11] show_sas GetLSVDNbyIP build_params_for_app isLoginAttemptsExceededThreshold marcipan_halted	FwIkeNewNegCxt FUN_081d7f40 init_dummy_conn_for_tcpt_IP fwisakmp_delete_peer_sa send_dpd_notification_IKEV1 RastaConnection resolve_multiple_interfaces release_IP_address_for_user FwResolverDBSetStat obtain_IP_address_for_user dhcp_init FUN_080fcd70 ikev2_sa_rekey_trap fwIsakmp_SAFFromNegCxt vpn_inc_status_VPND_counter FUN_082f7de0 tnlmon_add_monitored_gateway process_cpas_tcpt_IKE_trap cleanLoginOptionsSet is_user_SLP_excluded sslt_init vpn_d_cmain rdp_status_handler FUN_080bd101 pmids_for_printing is_vpn_cluster_on_aws tcptapi_send tcpthash_find FUN_08106c10 FUN_08180b80 getTableEntry getUseCRLRevocationMethodFor snxIpAddressToStr[abi:cxx11] FUN_0830dec0 ComputeNatDHashes FUN_080ef090 cplic_add_shared_license_in getIKEVersionForRA cpIkeSignCB FUN_080e5f80 handleLsvPeer
--	--	---	--	---	---

How to analyze and sort this massive list?

Could try to:

- ✦ Send all 293 functions to GPT-4 to rank.
 - ...but the context window is **too small** for that.
- ✦ Send each function separately for GPT-4 to score.
 - ...but GPT-4 has a *strong* tendency to **inflate scores**. (CVSS, anyone?)
- ✦ Divide and conquer: break into small groups, sort, and merge.
 - ...but randomness/**nondeterminism** makes this pretty unreliable.
- ✦ So, what now?

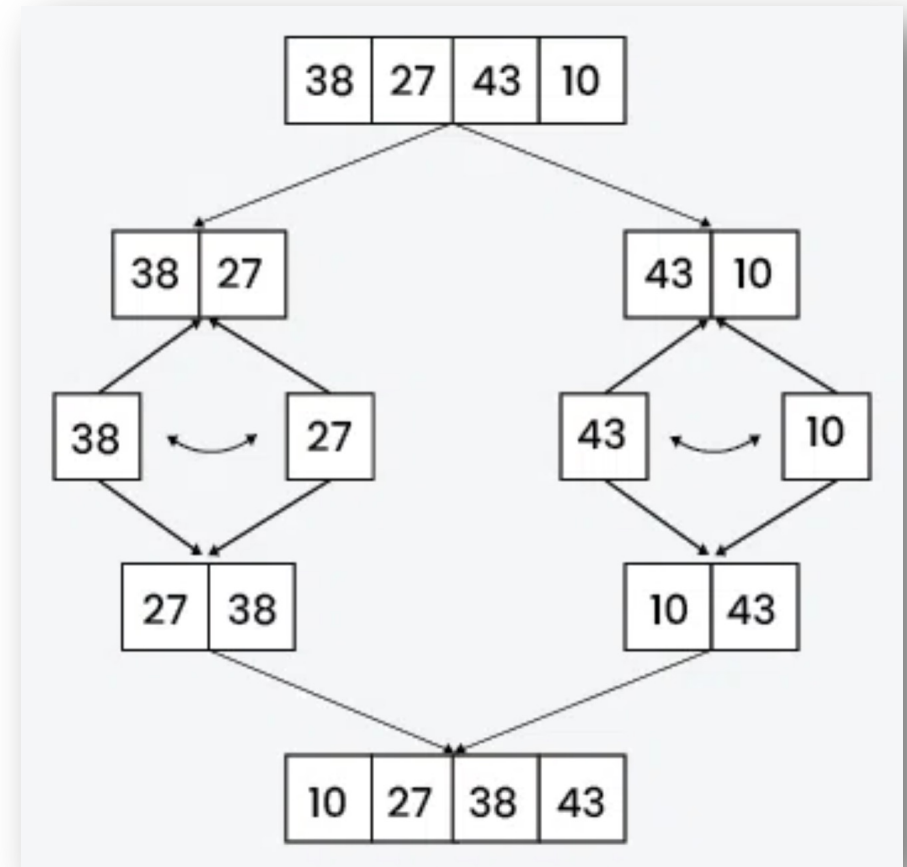


How to analyze and sort this massive list?

Could try to:

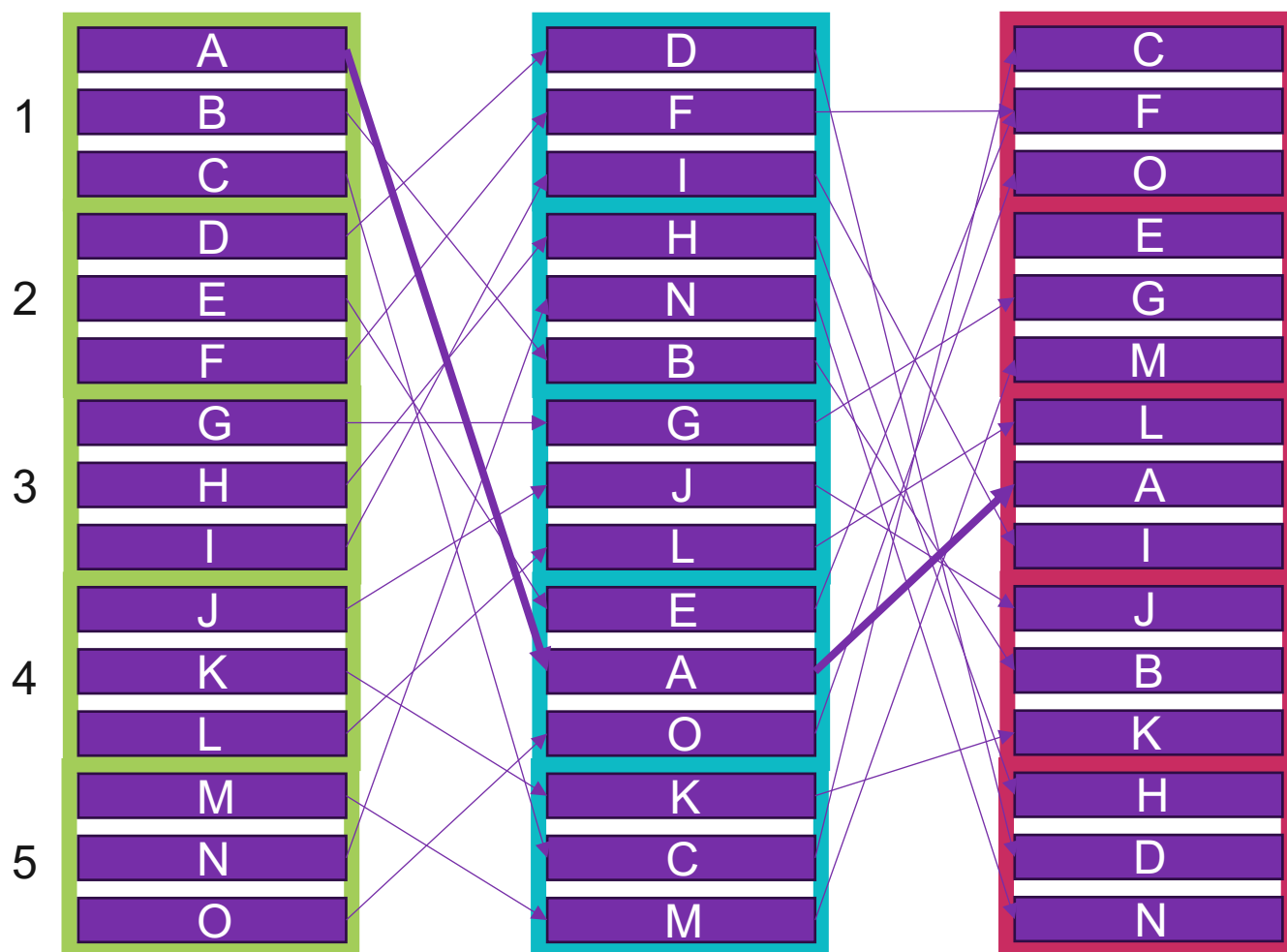
- ◆ Send all 294 functions to GPT-4 to rank.
 - ...but the context window is **too small** for that.
- ◆ Send each function separately for GPT-4 to score.
 - ...but GPT-4 has a *strong* tendency to **inflate scores**. (CVSS, anyone?)
- ◆ Divide and conquer: break into small groups, sort, and merge.
 - ...but randomness/**nondeterminism** makes this pretty unreliable.
- ◆ So, what now?

Enter: Multi-Sample Sort.



Multi-Sample Sort

Sample and sort **multiple times**, and **average the rankings** to help mitigate the effects of the LLM's nondeterminism.



A	1, 2, 2 => 1.66
B	2, 3, 2 => 2.33
C	3, 2, 1 => 2
D	1, 1, 2 => 1.33
E	2, 1, 1 => 1.33
F	...
G	
H	
I	3, 3, 3 => 3
J	
K	
L	
M	
N	
O	

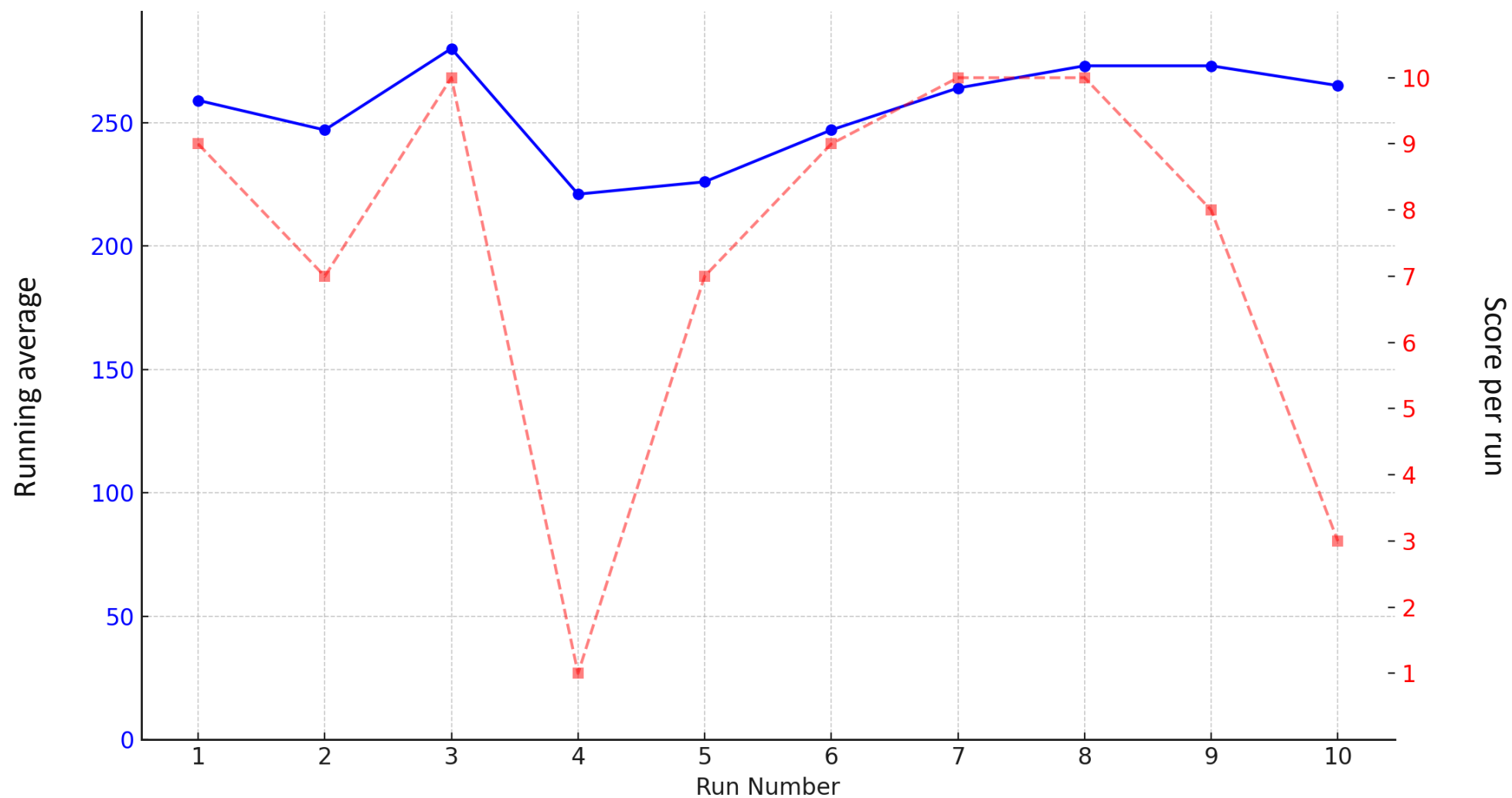
Multi-Sample Sort: What's in a name?



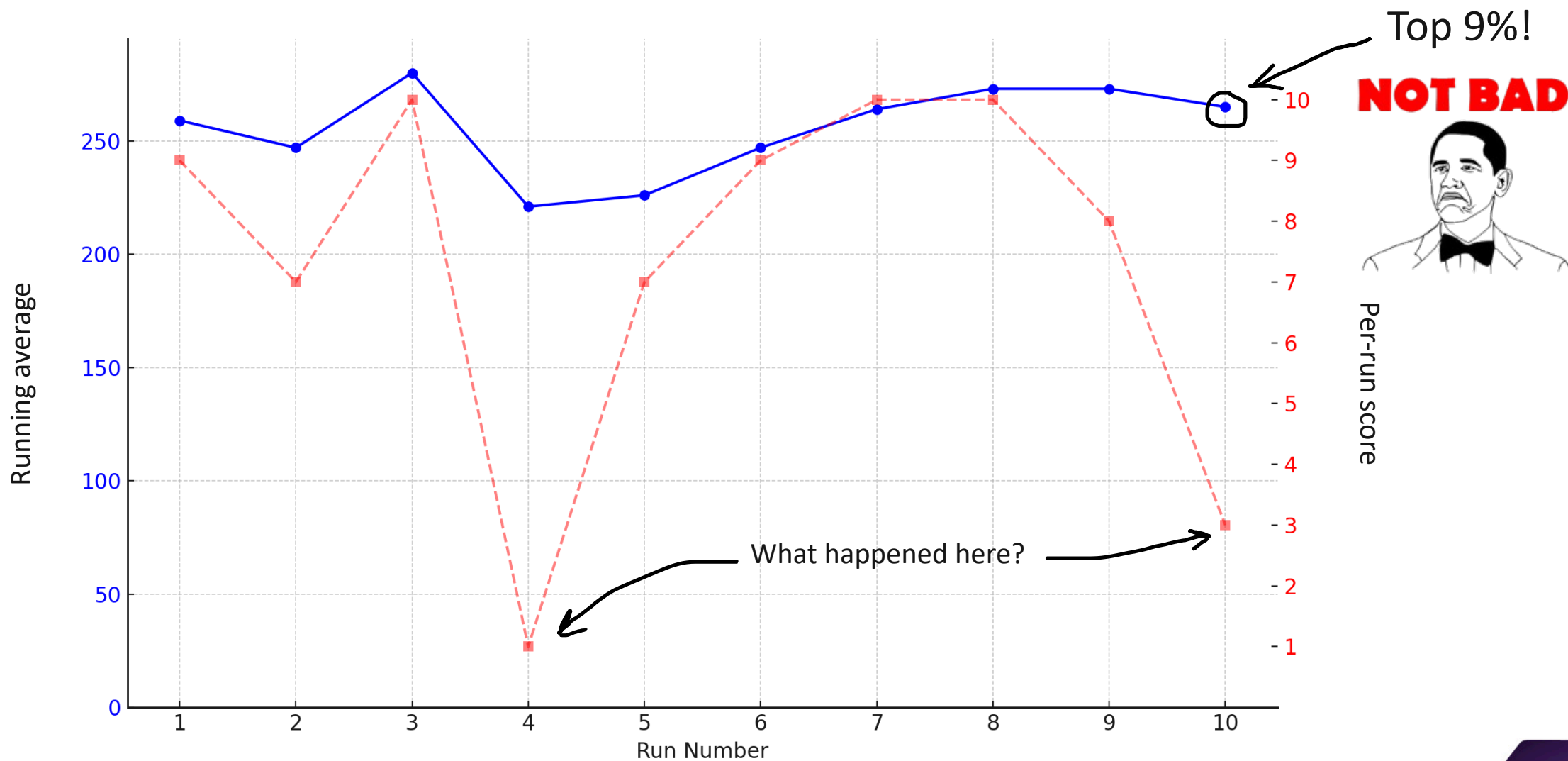
Averaged Sample Sort 🙅

Multi-Sample Sort (MSS) 👍

Multi-Sample Sort: Running Average



Multi-Sample Sort: Running Average



What were we competing with?



verifyCert	The function adds additional checks and error handling related to certificate validation and realm name comparison , which directly addresses the exposure of sensitive information.
isakmp_check_user_limitations	The function adds checks for legacy authentication and VPN-specific conditions , which are directly related to the remote access components mentioned in the advisory.
unban_client_ip_address	The function deals with unbanning client IP addresses and resetting failed attempts , which are directly related to preventing unauthorized access and exposure of sensitive information. The changes include error handling.
verify_peer_auth	The function verifies peer authentication , which is directly related to preventing unauthorized access. The changes include additional logging and error handling, which are crucial for identifying and mitigating unauthorized access.
AUAuthIOFunc	The function includes changes in error handling and negotiation retrieval , which are critical for preventing unauthorized access to sensitive information. The changes directly relate to the authentication component, which is crucial for preventing unauthorized access.
rdp_status_handler	The function adds error handling for setting cryptographic resolver tables , which is crucial for preventing unauthorized access to sensitive information.
updateTableEntry	The function updateTableEntry directly handles IP address validation and sets penalties for brute force attacks , which aligns with the advisory's focus on preventing unauthorized access and exposure of sensitive information.
ikev2_validate_peer_cert	The function directly deals with peer certificate validation , which is crucial for preventing unauthorized access and exposure of sensitive information.
vpn_ikesa_deleted_trap	The function includes changes related to user session management and logging , which are critical for preventing unauthorized access and ensuring sensitive information is not exposed.
IsUserAuthenticatedWithMachineCert	This function checks user authentication using a machine certificate , which is directly related to preventing unauthorized access, aligning with the advisory's focus on sensitive information exposure.
http_vpnd_fetch_user_cb	The function includes extensive changes related to user authentication and error handling , which are directly related to preventing unauthorized access and exposure of sensitive information.
isLoginAttemptsExceededThreshold	The function checks for brute force attack prevention , which is directly related to security and preventing unauthorized access, addressing the CVE's concern about unauthorized information exposure.
vpn_update_isakmp_user	The function includes changes to user and certificate handling , which are directly related to the vulnerability described in the advisory.
FUN_080ef090	The function adds brute-force attack prevention logic, which is directly related to preventing unauthorized access to the VPN and remote access components.
IKE_LS_Resolver_Logic	The function includes changes in error handling and logging , which are critical for preventing unauthorized access to sensitive information. The changes directly relate to the IKE (Internet Key Exchange) component, which is crucial for preventing unauthorized access.
call_dpd_callback	The function involves handling DPD callbacks , which is not directly related to the information exposure vulnerability described in the advisory.
resetFailedAttempts	The function is related to brute force attack prevention , which is crucial for securing VPN access. The changes include validation and error handling, which could prevent unauthorized access.
L2TP_enforce_PPP_user_limitations	The function includes changes in error handling and user authentication , which are critical for preventing unauthorized access to sensitive information. The changes directly relate to the L2TP (Layer 2 Tunneling Protocol) component, which is crucial for preventing unauthorized access.
free_challenge_buf	The function safely frees a challenge buffer with appropriate logging and state resetting, directly addressing potential exposure of sensitive information.
removeTableEntry	The function validates IP addresses and removes invalid entries, which directly addresses the exposure of sensitive information by ensuring only valid IP addresses are processed.
geOrCreatetLogUidForlkeCCC	The function involves session management and error handling , which are critical for preventing unauthorized access and exposure of sensitive information.
send_message	The function sends messages over a connection, which is related to network communication. The added validation check ensures the connection is valid, preventing unauthorized information exposure.
updateFailedAttempts	The function addresses brute force attack prevention , which is a security measure, but not directly related to the described vulnerability.
FwlkeAfterAsyncCertHandling	The function updates offsets and arguments related to certificate handling and community names, which are critical for secure communication and preventing unauthorized access.
http_vpnd_check_user_grps_cb	The function includes checks for brute force attack prevention, input validation, and error handling , which directly relate to mitigating the exposure of sensitive information.
getUseCRLRevocationMethodFromRegistry	This function directly interacts with registry settings related to CRL revocation, which is crucial for preventing unauthorized access and mitigating the exposure of sensitive information.
receive_fwuserc_isakmp_reply_S	The function includes significant changes to error handling, logging, and session handling , which are likely aimed at preventing unauthorized access and exposure of sensitive information. These changes are directly related to the vulnerability described in the advisory.
FUN_080f0790	The function involves logging and handling potential path traversal attacks , which is important for security but not directly related to the specific vulnerability described.
authenticate	The function handles authentication , which is crucial for remote access VPN security. The refactor improves error handling, session management, and logging, addressing potential unauthorized access to sensitive information.
is_user_SLP_excluded	The function checks user exclusion from SLP , which is a security measure but not directly related to the described vulnerability.



What were we competing with?

- verifyCert
- isakmp_check_user_limitations
- unban_client_ip_address
- verify_peer_auth
- AUAuthIOFunc
- rdp_status_handler
- updateTableEntry
- ikev2_validate_peer_cert
- vpn_ikesa_deleted_trap
- IsUserAuthenticatedWithMachineCert
- http_vpnd_fetch_user_cb
- isLoginAttemptsExceededThreshold
- vpn_update_isakmp_user
- FUN_080ef090
- IKE_LS_Resolver_Logic
- call_dpd_callback
- resetFailedAttempts
- L2TP_enforce_PPP_user_limitations
- free_challenge_buf
- removeTableEntry
- geOrCreatetLogUidForIkeCCC
- send_message
- updateFailedAttempts
- FwIkeAfterAsyncCertHandling
- http_vpnd_check_user_grps_cb
- getUseCRLRevocationMethodFromRegistry
- receive_fwuserc_isakmp_reply_S
- FUN_080f0790**
- authenticate
- is_user_SLP_excluded

The function adds additional checks and error handling related to **certificate validation and realm name comparison**, which directly addresses the exposure of sensitive information.

The function adds checks for **legacy authentication and VPN-specific conditions**, which are directly related to the remote access components mentioned in the advisory.

The function deals with **unbanning client IP addresses and resetting failed attempts**, which are directly related to preventing unauthorized access and mitigating brute force attacks.

The function **verifies peer authentication**, which is directly related to preventing unauthorized access. The changes include additional logging and error handling.

The function includes changes in **error handling and negotiation retrieval**, which are critical for preventing unauthorized access to sensitive information.

The function adds error handling for setting **cryptographic resolver tables**, which is crucial for preventing unauthorized access to sensitive information.

The function updateTableEntry directly handles **IP address validation and sets penalties for brute force attacks**, which aligns with the advisory's focus on preventing unauthorized access.

The function directly deals with peer **certificate validation**, which is crucial for preventing unauthorized access and exposure of sensitive information.

The function includes changes related to **user session management and logging**, which are critical for preventing unauthorized access and exposure of sensitive information.

This function checks **user authentication using a machine certificate**, which is directly related to preventing unauthorized access, aligning with the advisory's focus on secure communication.

The function includes extensive changes related to **user authentication and error handling**, which are directly related to preventing unauthorized access and exposure of sensitive information.

The function checks for **brute force attack prevention**, which is directly related to security and preventing unauthorized access, addressing the CVE's core vulnerability.

The function includes changes to **user and certificate handling**, which are directly related to the vulnerability described in the advisory.

The function adds **brute-force attack prevention** logic, which is directly related to preventing unauthorized access to the VPN and remote access components.

The function includes changes in **error handling and logging**, which are critical for preventing unauthorized access to sensitive information. The changes include additional logging and error handling.

The function involves handling **DPD callbacks**, which is not directly related to the information exposure vulnerability described in the advisory.

The function is related to **brute force attack prevention**, which is crucial for securing VPN access. The changes include validation and error handling, which are critical for preventing unauthorized access.

The function includes changes in **error handling and user authentication**, which are critical for preventing unauthorized access to sensitive information.

The function safely frees a **challenge buffer** with appropriate logging and state resetting, directly addressing potential exposure of sensitive information.

The function **validates IP addresses** and removes invalid entries, which directly addresses the exposure of sensitive information by ensuring only valid IP addresses are used.

The function involves **session management and error handling**, which are critical for preventing unauthorized access and exposure of sensitive information.

The function sends messages over a connection, which is related to network communication. The added validation check ensures the connection is valid, preventing unauthorized access.

The function addresses **brute force attack prevention**, which is a security measure, but not directly related to the described vulnerability.

The function updates offsets and arguments related to certificate handling and community names, which are critical for secure communication and preventing unauthorized access.

The function includes checks for **brute force attack prevention, input validation, and error handling**, which directly relate to mitigating the exposure of sensitive information.

This function directly interacts with registry settings related to CRL revocation, which is crucial for preventing unauthorized access and mitigating the exposure of sensitive information.

The function includes significant changes to **error handling, logging, and session handling**, which are likely aimed at preventing unauthorized access and exposure of sensitive information.

The function involves **logging and handling potential path traversal attacks**, which is important for security but not directly related to the specific vulnerability.

The function handles **authentication**, which is crucial for remote access VPN security. The refactor improves error handling, session management, and logging.

The function checks **user exclusion from SLP**, which is a security measure but not directly related to the described vulnerability.

Brute force prevention

Session handling

Authentication

Path traversal

CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

Summary



Given an advisory and patch diff, we can:

- ✓ Describe each changed function
- ✓ Determine if it's a security-related change
- ✓ Estimate how likely the change fixed a given vulnerability
- ✓ **Use multi-sample sort to scale analysis beyond context window limit**
- ✓ List the most likely candidates

...and give a human (in the loop) a *much* better starting place for manual analysis.

Further Research



- ◆ More context!
 - Full incoming/outgoing call tree
 - *Summarize* those functions, too
 - ...and *rename* stripped functions
- ◆ Dynamic testing
 - Employ LLM agent w/RE tools
 - Simple crash PoC
 - Fuzzing
 - Exploit development
- ◆ Other models
 - Competing vendors: Anthropic, etc.
 - *Specific* domain (Code Llama) vs. general domain (ye regular ole Llama)
- ◆ Cross-reference code with product documentation
 - Embed admin/developer docs via RAG
 - “Which component might this decompiled code relate to?”
- ◆ Do the statistics more better
 - For multi-sample scoring—prune outliers? Is that bad? Ask Ben 🙄
 - Test smaller or bigger sample sizes
- ◆ Improve the various prompts
 - What does this diff do? Rank these functions, etc.
 - Assign Boolean attributes to help with objective comparison

Thank You.

Questions?

